

Use Case: AI Architecture Assessment Agent

1. Amaç

AI Architecture Assessment Agent, uygulama kaynak kodu ve ilgili teknik artifact'leri analiz ederek kurumsal mimari, güvenlik, kalite, DevOps ve operasyon standartlarına uyumunu otomatik olarak değerlendiren ve kanıta dayalı iyileştirme önerileri üreten bir yapay zeka ajanıdır.

6. Agent Detayları ve Kabul Kriterleri

6.1 Kod ve Proje Yapısı Standartları

Kontrol kapsamı: Solution ve proje yapısı, katman ayrımı, dependency yönleri, circular dependency, isimlendirme standartları, ortak bileşen kullanımı, business logic konumlandırması, controller sorumlulukları ve dependency injection kullanımı.

Kabul kriteri: Agent, mimari ihlali doğru tespit etmeli, ilgili dosya/proje/metot bilgisini göstermeli, ihlal edilen Holding standardını belirtmeli ve uygulanabilir refactoring önerisi sunmalıdır.

6.2 Kimlik Doğrulama ve Yetkilendirme

Kontrol kapsamı: Microsoft Entra ID veya kurumsal kimlik altyapısı, authentication yapılandırması, endpoint bazlı authorization, rol/claim/permission kontrolleri, anonymous endpointler, token validation, 401/403 kullanımı ve service-to-service kimlik doğrulaması.

Kabul kriteri: Agent, korumasız endpointleri tespit etmeli, endpoint veya metot seviyesinde kanıt göstermeli, authentication ile authorization farkını doğru değerlendirmeli ve yetkisiz erişim etkisini açıklamalıdır.

6.3 Uygulama Güvenliği ve Secret Yönetimi

Kontrol kapsamı: Hardcoded secret, API key, connection string, Key Vault kullanımı, input validation, SQL Injection, CORS ayarları, güvenlik headerları, hassas veri loglama ve güvensiz şifreleme yöntemleri.

Kabul kriteri: Agent, güvenlik açığını doğru sınıflandırmalı, secret değerlerini raporda açık göstermemeli, kanıtı dosya/satır bilgisiyle sunmalı, güvenli alternatif önermeli ve kritik bulguları yüksek öncelikle raporlamalıdır.

6.4 Veri Yönetimi ve Entegrasyon Standartları

Kontrol kapsamı: Veritabanı erişim standartları, migration yönetimi, transaction kullanımı, timeout ve retry politikaları, API istemci yönetimi, kişisel/hassas veri kullanımı, harici servis bağımlılıkları ve API versioning.

Kabul kriteri: Agent, veri tutarlılığı veya entegrasyon dayanıklılığı etkisini açıklamalı, ilgili kod bloğunu göstermeli, genel öneri yerine teknik çözüm sunmalı ve retry önerirken idempotency riskini dikkate almalıdır.

6.5 Loglama, İzlenebilirlik ve APM

Kontrol kapsamı: Structured logging, Application Insights entegrasyonu, correlation ID, distributed tracing, merkezi exception handling, log seviyeleri, hassas veri maskeleyme, dependency tracking, health ve telemetry yapılandırması.

Kabul kriteri: Agent, observability eksikliğini doğru tespit etmeli, loglama ile monitoring kavramlarını karıştırmamalı, hassas veri loglarını güvenlik riskiyle ilişkilendirmeli ve kurum standardına uygun çözüm önermelidir.

6.6 Test ve Kod Kalitesi Standartları

Kontrol kapsamı: Unit ve integration testlerin varlığı, kritik iş kurallarının test edilmesi, test projesi yapısı, mock kullanımı, SonarQube yapılandırması, code coverage, cyclomatic complexity, duplicate code ve testlerin pipeline içinde çalıştırılması.

Kabul kriteri: Agent, yalnızca test dosyası sayısına bakmamalı; assertion kalitesini, kritik akışların test edilip edilmediğini, quality gate durumunu ve test piramidine uygun iyileştirme ihtiyacını değerlendirmelidir.

6.7 CI/CD ve Kaynak Kod Yönetimi

Kontrol kapsamı: Pipeline dosyaları, build ve test adımları, code quality gate, security/dependency scanning, artifact yönetimi, ortam bazlı deployment, production onayı, secret kullanımı, branch ve PR politikalarına ilişkin mevcut kanıtlar.

Kabul kriteri: Agent, pipeline dosyalarını analiz etmeli, eksik aşamaları doğru sıralamayla açıklamalı, kaynak koddan doğrulanamayacak branch policy konularında varsayım yapmamalı ve kanıt yoksa Değerlendirilemedi statüsünü kullanmalıdır.

6.8 Container ve Çalışma Ortamı Standartları

Kontrol kapsamı: Dockerfile varlığı, onaylı base image, multi-stage build, non-root çalışma, image boyutu, port ve health check, environment variable kullanımı, secret yönetimi, CPU/memory limitleri ve stateless çalışma.

Kabul kriteri: Agent, Dockerfile ve deployment manifestlerini birlikte değerlendirmeli, güvenlik ve operasyon risklerini ayrı açıklamalı, uygun base image veya non-root çalışma önermeli ve kanıtı olmayan altyapı konularında varsayım yapmamalıdır.

6.9 Performans, Dayanıklılık ve Ölçeklenebilirlik

Kontrol kapsamı: Asenkron programlama, blocking çağrılar, N+1 sorgular, cache kullanımı, timeout, retry, circuit breaker, background job, idempotency, büyük veri sorguları, stateless tasarım ve yatay ölçeklenebilirlik.

Kabul kriteri: Agent, potansiyel ve kesin performans sorunlarını ayırmalı, sorunun etkisini açıklamalı, ölçüm gerektiren konularda kesin hüküm vermemeli ve profiling veya yük testi ihtiyacını belirtebilmelidir.

6.10 Dokümantasyon ve Mimari Yönetişim

Kontrol kapsamı: README, kurulum açıklamaları, mimari diyagram, API dokümantasyonu, ADR kayıtları, teknoloji envanteri, uygulama sahibi, destek modeli ve operasyonel sorumluluklar.

Kabul kriteri: Agent, dokümanın yalnızca varlığını değil yeterliliğini değerlendirmeli, eksikleri göstermeli, koddan çıkarılan mimari görünümü özetlemeli ve kullanılabilir içerik şablonu önermelidir.